Modulo 3

AWS Security, Identity y Compliance

Curso: AWS Cloud Practitioner Essentials

5 horas

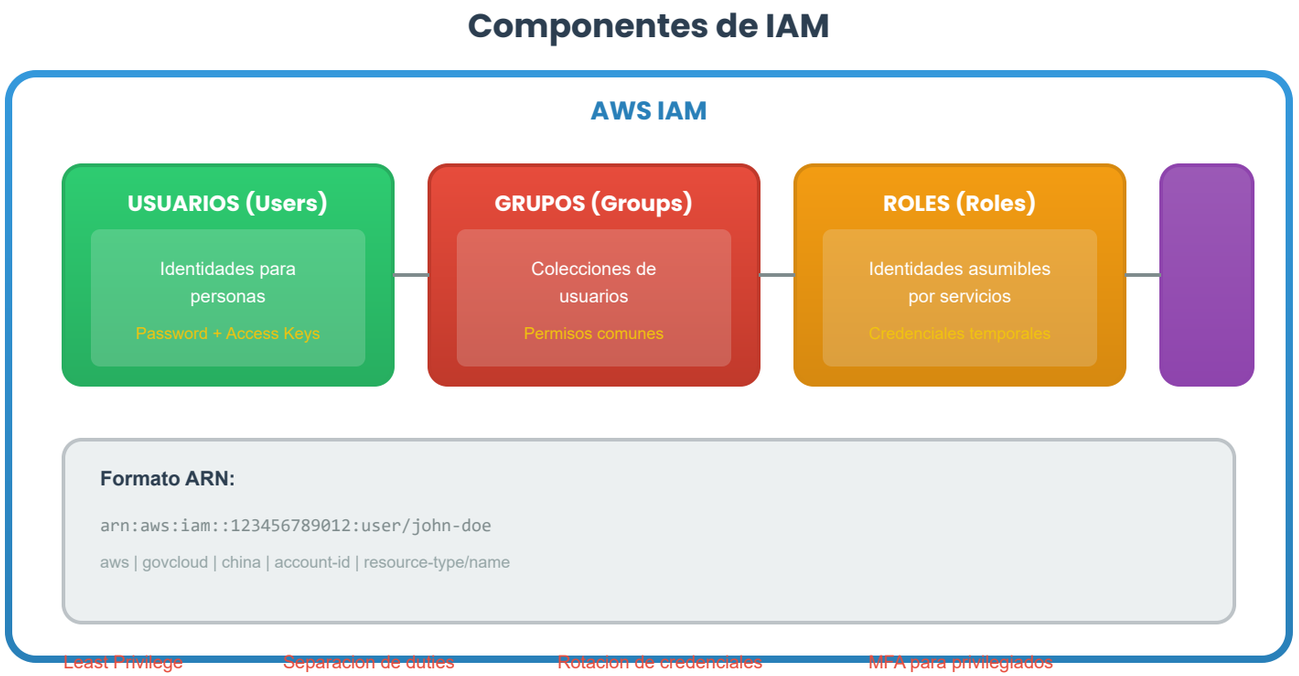
Objetivos de Aprendizaje

- Implementar seguridad en AWS utilizando IAM (usuarios, grupos, roles, politicas)
- Aplicar politicas JSON para control de acceso granular
- Configurar roles de IAM para servicios AWS y federation
- Implementar Multi-Factor Authentication (MFA)
- Explicar y aplicar cifrado para datos en reposo y en transito usando KMS
- Configurar cifrado en S3 (SSE-S3, SSE-KMS, SSE-C)
- Configurar logging y auditoria con CloudTrail y CloudWatch
- Describir servicios adicionales: GuardDuty, Security Hub, Shield, WAF
- Implementar permission boundaries y SCPs
- Gestionar acceso cross-account usando roles

1. AWS Identity and Access Management (IAM)

Gestion de identidades y accesos

Componentes de IAM



Usuarios y Credenciales IAM

Tipo	Uso	Rotacion
Password	Console login	Manual
Access Keys	CLI/SDK	Manual o programatico
SSH Keys	CodeCommit	Manual
Server Certificates	SSL/TLS	Manual

Best practices: No usar root excepto tareas iniciales, habilitar MFA inmediatamente

Grupos de IAM

Proposito: Facilitar gestion de permisos para multiples usuarios

```
IT Department
├── SysAdmin
│   └── Policy: AdministratorAccess
├── Developer
│   └── Policy: EC2 + S3 Read/Write + CloudWatch
└── Auditor
    └── Policy: ReadOnlyAccess
```

Roles de IAM

Que es un Role: Identidad con permisos que puede ser asumida por servicios o usuarios

Casos de uso:

- Servicio a servicio (EC2 → S3)
- Usuarios federados
- Cross-account access
- Aplicaciones (Lambda → DynamoDB)

STS (Security Token Service):

- Credenciales temporales
- AssumeRole para asumir roles
- Duracion: 1-12 horas

Politicas de IAM - Estructura JSON

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": ["s3:GetObject", "s3:ListBucket"],
    "Resource": "arn:aws:s3:::mi-bucket/*",
    "Condition": {
      "IpAddress": {"aws:SourceIp": "192.168.1.0/24"}
    }
  }]
}
```

Tipos de Politicas

Tipo	Alcance	Uso
AWS Managed	Todas las cuentas	Roles predefinidos por AWS
Customer Managed	Una cuenta	Politicas custom reutilizables
Inline	Recurso especifico	Por recurso, no reutilizable
Permission Boundary	Users/Roles	Limite maximo de permisos

Lab 3.1: Configuracion de IAM

75 minutos

Objetivo

Crear estructura de IAM completa: usuarios para diferentes roles, grupos con politicas, y roles para servicios AWS.

Pasos del Lab

1. Crear usuarios: admin-juan, dev-maria, analyst-pedro, app-service
2. Crear grupos: Administrators, Developers, Analysts con politicas gestionadas
3. Asignar usuarios a grupos
4. Crear politica personalizada para bucket de proyecto
5. Crear rol EC2S3ReadOnlyRole para servicio EC2
6. Habilitar MFA para usuarios privilegiados

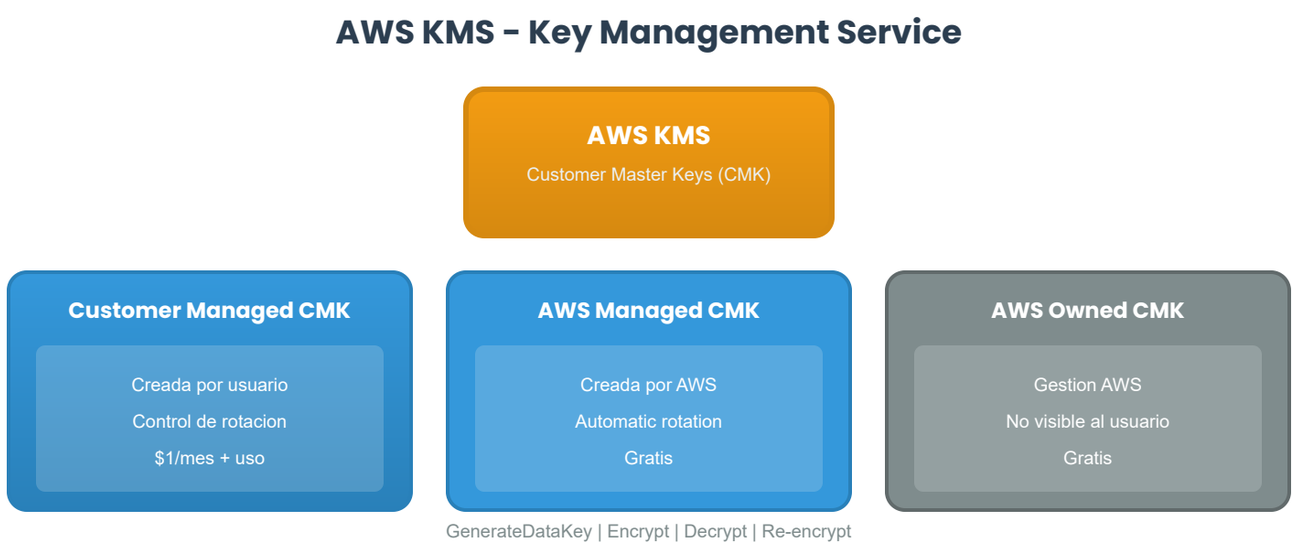
2. Cifrado y Seguridad de Datos

Proteccion de datos en reposo y en transito

Tipos de Cifrado

Tipo	Descripcion	Uso
En reposo (At Rest)	Datos almacenados	EBS, S3, RDS
En transito (In Transit)	Datos moviendose	TLS, SSL
Cliente-side	Datos cifrados antes de enviar	S3 client-side

AWS KMS - Key Management Service



Cifrado en S3

Cifrado en EBS

- Cifrado automatico con CMK gestionada por KMS
- Todos los snapshots asociados tambien cifrados
- No hay impacto en performance (~3% overhead)

Opciones:

1. Cifrado por defecto en cuenta (gratis)
2. Cifrar volumen especifico al crear
3. Cifrar al lanzar instancia en wizard

Lab 3.2: Cifrado S3 con KMS

60 minutos

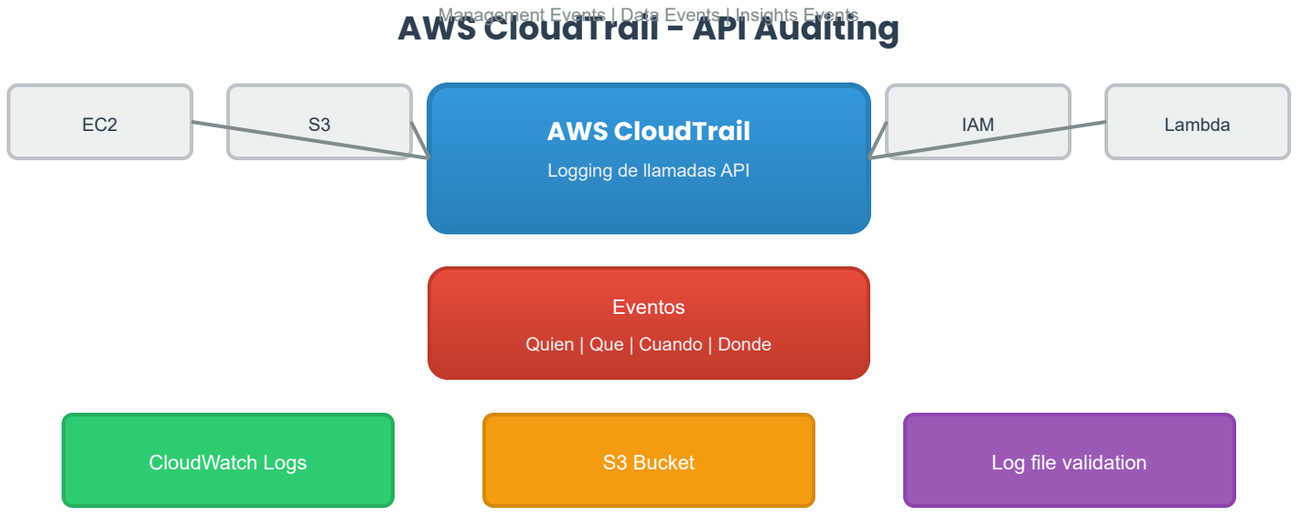
Pasos del Lab

1. Crear CMK en KMS con alias "mi-clave-cifrado"
2. Crear bucket S3 con cifrado por defecto
3. Habilitar SSE-KMS con CMK personalizada
4. Crear bucket policy que requiera cifrado SSE-KMS
5. Verificar policy denegando uploads sin cifrado
6. Auditar uso de claves en CloudTrail

3. Logging, Monitoreo y Compliance

CloudTrail, CloudWatch y servicios de seguridad

AWS CloudTrail



Tipos de Eventos CloudTrail

Tipo	Descripcion
Read	Get, List, Describe
Write	Create, Delete, Update
Console	Login events
Insights	Detecta anomalias (90 dias retention)

CloudWatch Logs

Estructura:

```
Log group (ej: /aws/lambda/my-function)
  └── Log streams (instancias/contenedores)
        └── Log events (entradas individuales)
```

Integracion con CloudTrail para busqueda centralizada de eventos.

Servicios de Seguridad Adicionales

GuardDuty

Threat detection con ML

Fuentes: CloudTrail, VPC Flow Logs, DNS

Security Hub

Vista centralizada de security posture

Agrega findings de multiples servicios

AWS Shield y WAF

Servicio	Descripcion
Shield Standard	Proteccion DDoS basica (incluido)
Shield Advanced	$3,000/year + proteccion adicional
WAF	Web Application Firewall - SQL injection, XSS, geo-blocking

AWS Config

Registro y evaluacion de configuraciones de recursos

- Configuration Recorder: Graba cambios en recursos
- Config Rules: Evalua contra politicas desired state
- Conformance Packs: Coleccion de rules para compliance

Lab 3.3: CloudTrail y CloudWatch

60 minutos

Pasos del Lab

1. Crear CloudTrail con integracion CloudWatch Logs
2. Verificar que CloudTrail esta grabando eventos
3. Explorar CloudWatch Logs y encontrar eventos
4. Crear Metric Filter para ConsoleLogin
5. Crear Alarma en CloudWatch
6. Generar eventos de prueba y verificar

4. IAM Avanzado

Permission Boundaries, SCPs y Cross-Account

Permission Boundaries

Concepto: Define el maximo de permisos que puede tener una identidad

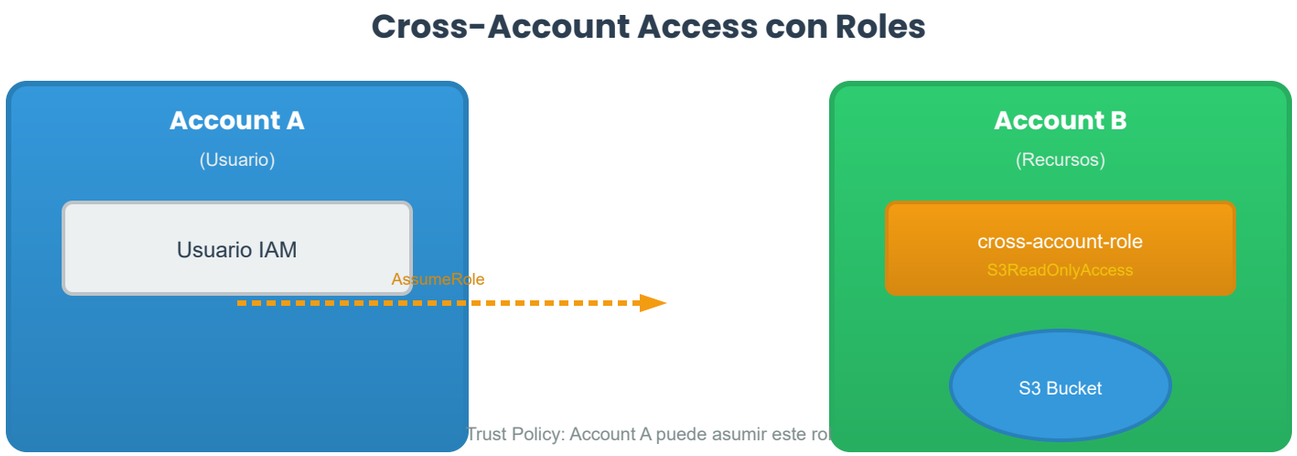
```
User: developer-juan
├── Attached Policy: AdministratorAccess (full access)
└── Permission Boundary: ReadOnlyAccess (limita a solo lectura)
→ Resultado: El usuario solo puede leer, no escribir
```

Service Control Policies (SCPs)

Concepto: Politicas de control en AWS Organizations a nivel de cuenta u OU

```
{
  "Statement": [{
    "Effect": "Deny",
    "Action": ["s3:DeleteBucket"],
    "Resource": "*"
  }]
}
```

Cross-Account Access



Condition Keys en Politicas

Key	Descripcion
aws:SourceIp	IP del solicitante
aws:RequestedRegion	Region solicitada
aws:MultiFactorAuthPresent	MFA habilitado
s3:x-amz-server-side-encryption	Tipo de cifrado S3

Lab 3.4: Roles Avanzados y Politicas Complejas

45 minutos

Pasos del Lab

1. Crear Permission Boundary personalizado
2. Crear usuario con Permission Boundary y verificar limites
3. Crear rol Cross-Account en segunda cuenta
4. Assumir rol y usar credenciales temporales
5. Crear Resource-Based Policy en bucket S3
6. Verificar Condition con MFA

Resumen

Puntos Clave

- **IAM:** Users, Groups, Roles, Policies - Least Privilege
- **KMS:** CMKs para cifrado simetrico, integrado con S3/EBS
- **S3 Encryption:** SSE-S3 (AWS managed), SSE-KMS (customer managed), SSE-C
- **CloudTrail:** API audit logging, multi-region, log validation
- **CloudWatch:** Centralized logging, metric filters, alarms
- **Permission Boundaries:** Limitan permisos maximos
- **Cross-Account:** Roles con trust policies para acceso entre cuentas

Referencias

Recursos Adicionales

- IAM Documentation
- AWS KMS Documentation
- S3 Encryption
- CloudTrail Documentation
- AWS Skill Builder

Gracias!

Modulo 3 Completado

Siguiente: Modulo 4 - Monitoring y Arquitectura